

Abdul Wahid

Lab Report

Social Engineering & Phishing Simulation (SET)

1. Executive Summary

This document provides a technical walkthrough of social engineering attacks executed using the Social-Engineer Toolkit (SET), an open-source framework developed by David Kennedy (ReL1K) at TrustedSec. All exercises were performed in a controlled lab environment for educational and authorized penetration testing purposes.

The report covers two primary attack chains:

- Mass Mailer Attack — Crafting and distributing phishing emails with a malicious reverse shell payload to a list of target addresses, using SET's built-in mailer combined with Metasploit payload generation.
- Credential Harvesting — Cloning legitimate login pages (Google, Facebook) to capture usernames and passwords from victims redirected via manipulated links.

Key outcomes observed during the lab:

- A Windows Reverse TCP Meterpreter payload (.exe) was successfully generated and hosted.
- A Netcat listener was configured to receive the incoming reverse shell connection.
- A credential harvester successfully captured a simulated username and password from a cloned Google login page in cleartext.
- A cloned Facebook page was served locally and confirmed visually identical to the real site.
- A deceptive Gmail link was crafted — displaying a trusted URL while redirecting to the attacker's cloned page.

> **Important:** SET is designed purely for lawful, authorized use. Performing these attacks on systems or individuals without explicit written permission is illegal and unethical.

Contents

1. Executive Summary 2
2. Introduction to SET 4
2.1 Tool Overview 4
2.2 Accepting Terms of Service 4
2.3 SET Main Interface 5
3. Mass Mailer Attack 6
3.1 Attack Flow Overview 6
3.2 Navigating to Mass Mailer 6
3.3 Payload Generation 8
3.4 Starting the Netcat Listener 10
3.5 Hosting the Payload 12
3.6 Link Shortening via Bitly 12
3.7 Crafting the Phishing Email 13
3.8 Preparing the Target Email List 14
3.9 Providing the Email List Path & SMTP Configuration 15
3.10 Delivery Result 16
4. Credential Harvesting 17
4.1 Navigating to the Credential Harvester 17
4.2 Template Method — Google Login Clone 18
4.3 Credentials Captured 19
5. Site Cloner — Directing Victims via Gmail Link Spoofing 21
5.1 Cloning the Target Website 21
5.2 Crafting the Deceptive Gmail Link 22
5.3 Victim Redirected to Cloned Page 24
6. Findings Summary 25
7. Conclusion 26

2. Introduction to SET

The Social-Engineer Toolkit (SET) is a royalty-free, open-source penetration testing framework designed specifically for social engineering attacks. It provides a suite of automated attack vectors that simulate tactics used by real-world threat actors.

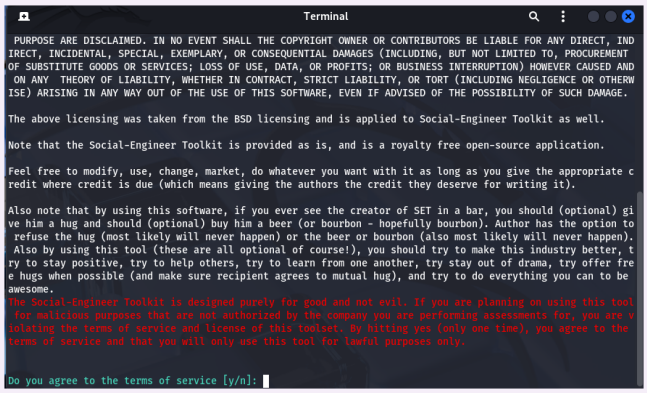
2.1 Tool Overview

Tool Name	Social-Engineer Toolkit (SET)
Version	8.0.3 — Codename 'Maverick'
Platform	Linux (Kali Linux recommended)

2.2 Accepting Terms of Service

SET requires the user to accept its terms of service before proceeding. The tool explicitly states it is designed for lawful use only. Entering 'y' accepts the agreement and moves to the main interface.

Step 1: Launch SET from the terminal. Read the license and accept by typing 'y' when prompted.



SET Terms of Service acceptance prompt

2.3 SET Main Interface

After accepting, the SET ASCII-art banner is displayed along with the main menu. The menu provides access to Social-Engineering Attacks, Penetration Testing (Fast-Track), Third Party Modules, and configuration options.

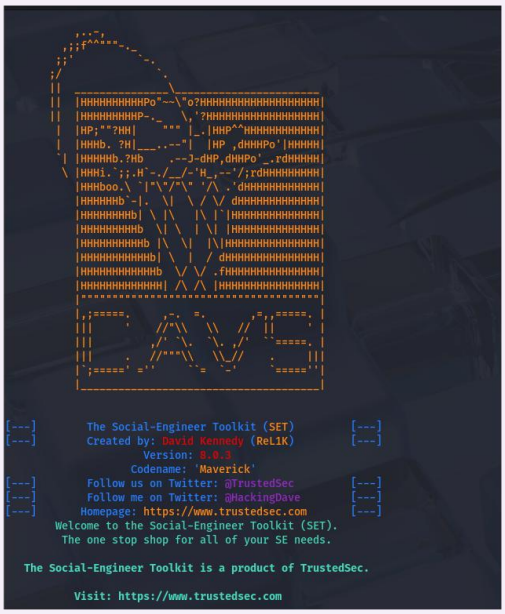


Fig 2.2 – SET ASCII banner and main menu interface

3. Mass Mailer Attack

The Mass Mailer Attack module enables a tester to send phishing emails to one or multiple recipients. It supports Gmail relay, custom SMTP, and Send mail/Postfix. This section documents both the payload generation phase and the email delivery phase.

3.1 Attack Flow Overview

1	Generate a malicious payload (.exe) using SET + Metasploit.
2	Start a Netcat listener to receive the incoming reverse shell connection.
3	Copy the payload to a web-accessible directory and serve it over HTTP.
4	Shorten the malicious URL using a link-shortener (e.g., Bitly) to obscure the destination.
5	Craft a phishing email containing the shortened link using a custom template.
6	Provide a target email list (.txt file) and configure Gmail/SMTP relay for sending.
7	Wait for the victim to click the link and execute the payload — connection received.

3.2 Navigating to Mass Mailer

From the SET main menu, select option 1 (Social-Engineering Attacks) to enter the attack vectors sub-menu.

Step 2: Select option 1 — Social-Engineering Attacks — from the SET main menu.

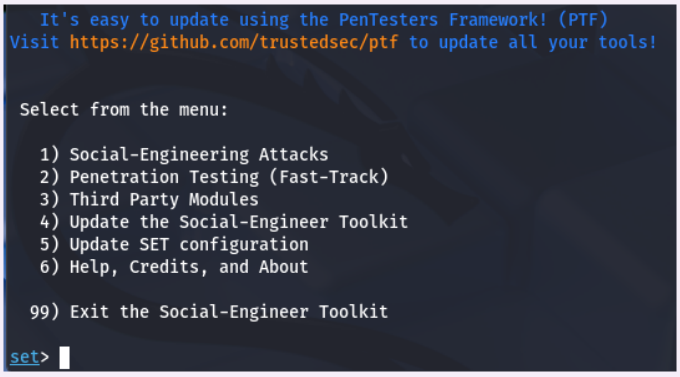


Fig 3.1 — SET main menu: selecting Social-Engineering Attacks (option 1)

From the Social Engineering Attacks sub-menu, select option 5 to enter the Mass Mailer Attack module.

Step 3: Select option 5 — Mass Mailer Attack — from the Social-Engineering Attacks sub-menu.

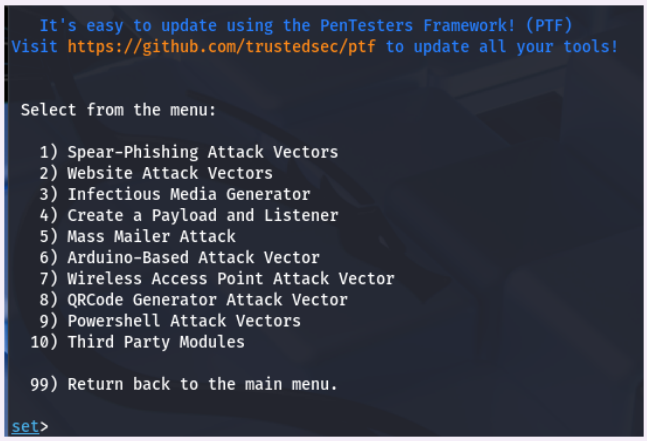


Fig 3.2 — Social-Engineering Attacks sub-menu: selecting Mass Mailer Attack (option 5)

The Mass Mailer module offers two options: send to a single email address, or import a list for bulk sending.

Step 4: Select option 2 — E-Mail Attack Mass Mailer — to send to multiple addresses via a list.

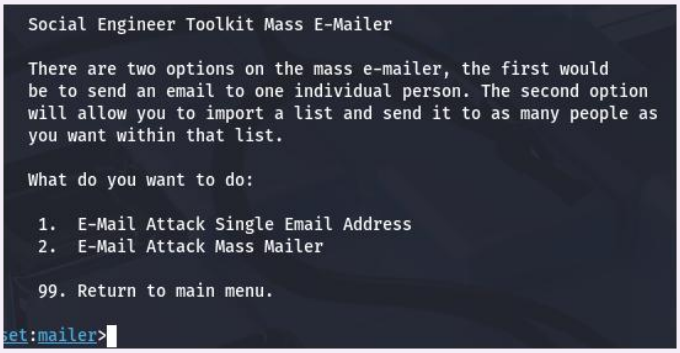
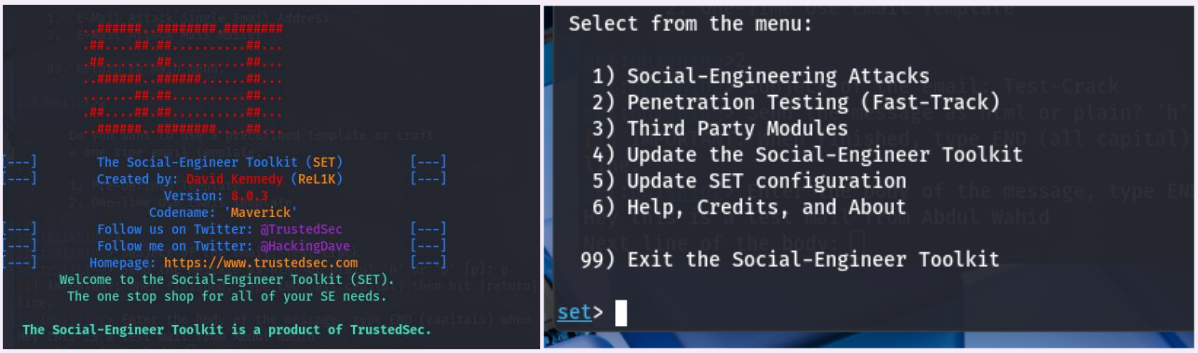


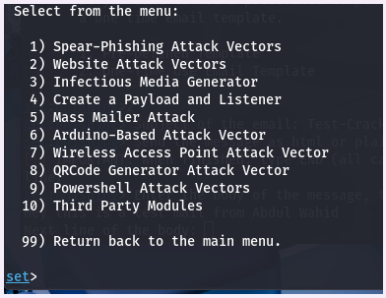
Fig 3.3 — Mass Mailer options: Single Email vs. Mass Mailer list import

3.3 Payload Generation

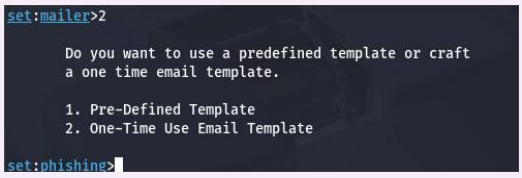
Before crafting the phishing email, a malicious payload must be generated. In a separate terminal, navigate back to the Social Engineering Attacks menu and select option 4 (Create a Payload and Listener). Choose Windows Reverse TCP Meterpreter as the payload type.

Step 5: Open a new terminal and return to SET. Select option 1 > option 4 (Create a Payload and Listener).

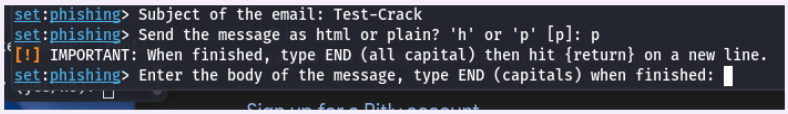




Create a Payload and Listener (option 4)



Create a one-time use template



Enter the credential's & in the body section we need to create a link to perform the attack

Step 6: Choose payload type 2 — Windows Reverse_TCP Meterpreter — from the payload selection menu.

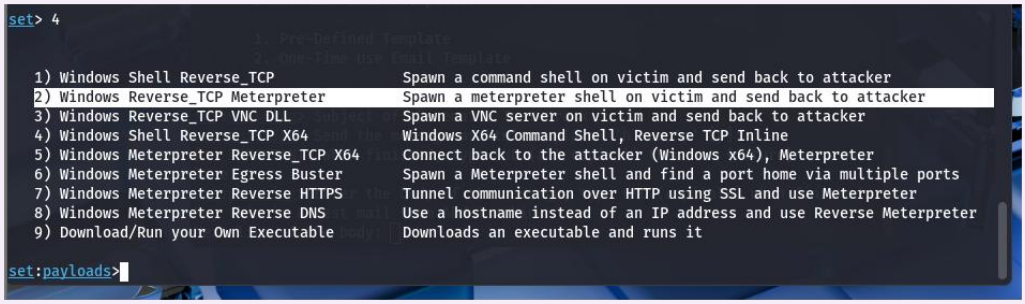


Fig 3.4 — Payload selection menu (Windows Reverse_TCP Meterpreter selected)

Enter the attacker's IP address (LHOST) and listener port (LPORT: 4444). SET generates the payload and saves it to /root/.set/payload.exe.

Step 7: Enter LHOST (attacker IP, e.g., 192.168.201.1) and LPORT (4444). SET generates the payload.

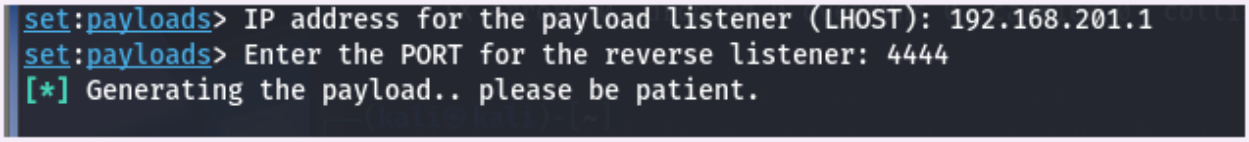


Fig 3.5 — LHOST and LPORT entry; payload generation in progress

3.4 Starting the Netcat Listener

While SET generates and launches the Metasploit listener automatically, a Netcat listener can also be started manually in a separate terminal to catch the reverse shell connection. This provides a quick fallback and confirms the port is open and listening.

Step 8: Open a new terminal and run: nc -lvnp 4444 to start listening for the incoming connection.

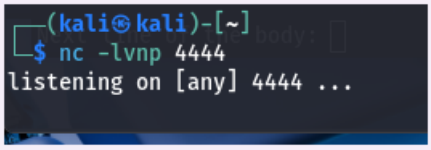


Fig 3.6 — Netcat listener active: listening on [any] port 4444

> **Note:** Netcat (nc -lvnp 4444) listens on all interfaces (-l), verbosely (-v), without DNS resolution (-n), and on the specified port (-p 4444). Once the victim executes the payload, a shell session opens here.

After confirming the payload and listener in SET, Metasploit Framework (msfconsole) launches automatically and begins listening for incoming connections on the configured port.

Step 9: Confirm 'yes' in SET to launch msfconsole. Wait for Metasploit to load fully.

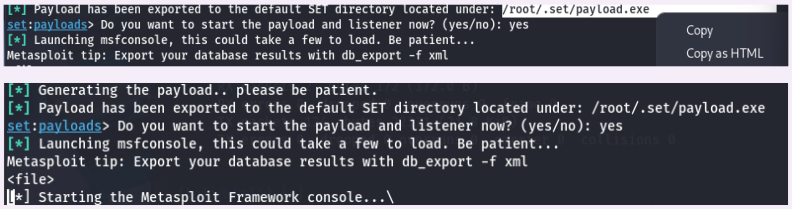


Fig 3.7 — SET confirming payload export and launching msfconsole



Fig 3.8 — Metasploit Framework console fully loaded; listener active on port 4444



Fig 3.9 — SET banner displayed confirming successful payload setup in the second terminal

3.5 Hosting the Payload

The generated payload is copied from /root/.set/ to a web-accessible directory (/home/kali) to be served over HTTP. Once hosted, its local URL can be shortened and embedded in the phishing email.

Step 10: Copy payload.exe to /home/kali using the cp command, then verify with ls.

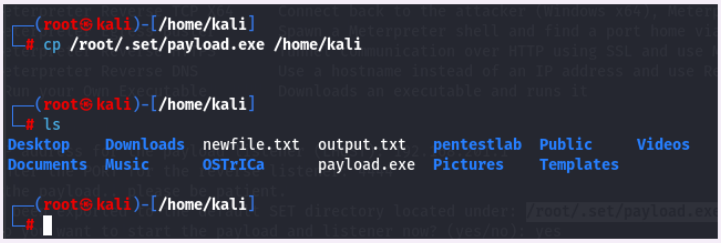


Fig 3.10 — Terminal: cp /root/.set/payload.exe /home/kali and ls confirming the file

3.6 Link Shortening via Bitly

The raw payload URL (e.g., http://192.168.80.129/payload.exe) is pasted into Bitly to generate a short, disguised link. This reduces suspicion when the link is embedded in an email body.

Step 11: Visit bitly.com, paste the payload URL, and click 'Get your link for free'.

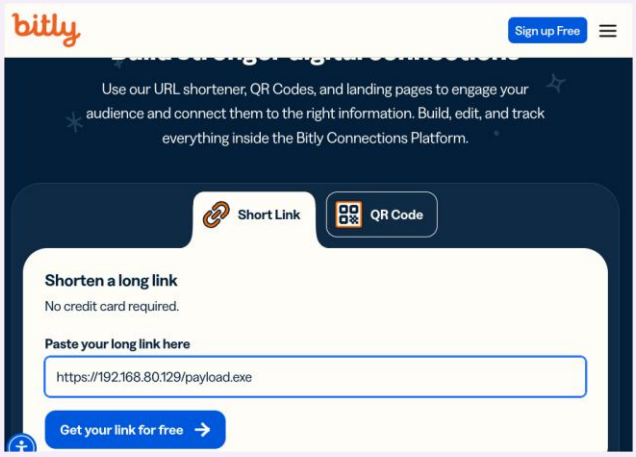


Fig 3.11 — Bitly interface: pasting the malicious payload URL for shortening

Step 12: Copy the generated shortened link (e.g., bit.ly/4b5E8No) for use in the phishing email.



Fig 3.12 — Bitly: shortened link confirmed and ready to copy

3.7 Crafting the Phishing Email

Back in SET, option 2 (E-Mail Attack Mass Mailer) is selected. When prompted for a template, choose option 2 (One-Time Use Email Template) to write a fully custom email. Enter the subject line and body text — the shortened Bitly link is pasted as the message body.

Step 13: Select option 2 (One-Time Use Email Template). Enter the email subject (e.g., 'Test-Crack').

Step 14: Enter the email body — paste the Bitly shortened link. Type END on a new line to finish.

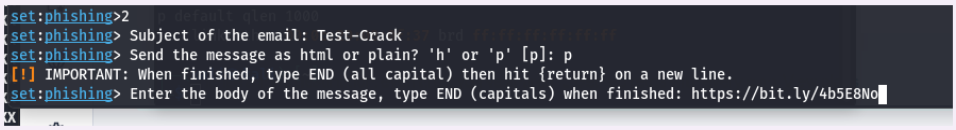


Fig 3.13 — SET phishing console: subject entry, format selection (plain), and Bitly link as body

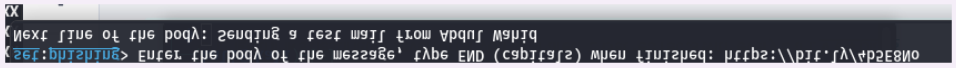


Fig 3.14 — SET phishing console: secondary message line added to body

3.8 Preparing the Target Email List

A plain-text file (emails.txt) is created containing one target email address per line. This file is saved to the Desktop. Temporary/disposable email services like TempMail can be used to safely generate test recipient addresses without using real inboxes.

Step 15: Create emails.txt on the Desktop with one email address per line.

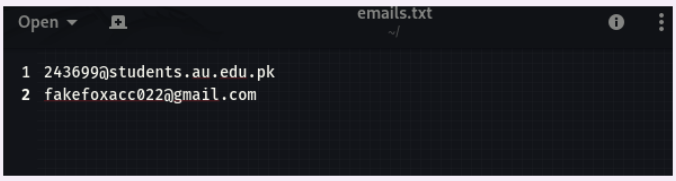


Fig 3.15 — emails.txt file showing target email addresses (one per line)

Step 16: Use TempMail or a similar service to generate a temporary inbox for safe testing.

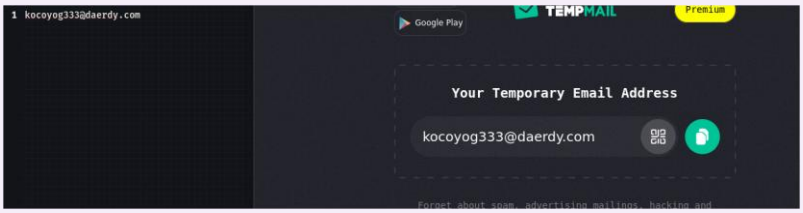


Fig 3.16 — TempMail: temporary email address generated for use as a test recipient

Step 17: Right-click emails.txt > Properties to confirm its full file path.

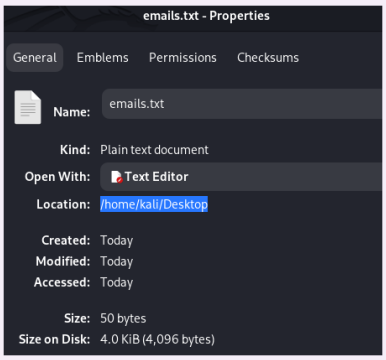


Fig 3.17 — File Properties: emails.txt located at /home/kali/Desktop, size 50 bytes

3.9 Providing the Email List Path & SMTP Configuration

SET prompts for the full path to the email list file. After entering it, the attacker selects Gmail as the sending relay and enters the Gmail address along with its App Password (not the regular account password).

Step 18: Enter the full file path when SET prompts: /home/kali/Desktop/emails.txt

```
set:phishing> Path to the file to import into SET: /home/kali/Desktop/emails.txt
```

Fig 3.18 — SET: file path entered as /home/kali/Desktop/emails.txt

Step 19: Select option 1 (Use a Gmail Account) and enter the sender Gmail address.

```
  1. Use a gmail Account for your email attack.
  2. Use your own server or open relay

set:phishing>1
set:phishing> Your gmail email address: a.wahid7860668@gmail.com
```

Fig 3.19 — SET: Gmail relay selected and sender email address entered

3.10 Delivery Result

During the lab, SET returned a password authentication error. This is a known issue when a Gmail App Password is not correctly configured or when too many failed attempts trigger a temporary lockout. The delivery flow is otherwise fully functional when credentials are valid.

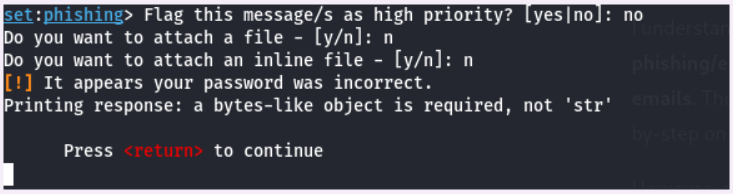


Fig 3.20 — SET delivery attempt: password authentication error message displayed

Note: The error 'It appears your password was incorrect' indicates a Gmail SMTP authentication issue — not a flaw in SET's mailer. To resolve: (1) Enable 2FA on the Gmail account, (2) Visit myaccount.google.com/apppasswords, (3) Create an app password named 'SET', (4) Use the generated 16-character password in place of your regular password.

4. Credential Harvesting

SET's Credential Harvester clones a target website and hosts it locally on the attacker's machine. When a victim is directed to the fake page and submits their login credentials, SET intercepts the POST request and displays the captured data in clear text in the terminal.

4.1 Navigating to the Credential Harvester

From the SET main menu, select option 1 (Social-Engineering Attacks), then option 2 (Website Attack Vectors). From the Website Attack Vectors menu, select option 3 (Credential Harvester Attack Method).

Step 20: From the SET main menu, select option 1 > option 2 (Website Attack Vectors).

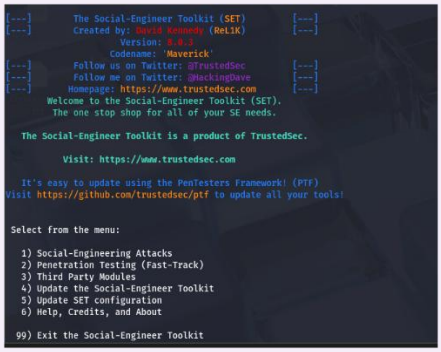


Fig 4.1 — SET main menu: returning to Social-Engineering Attacks for credential harvesting

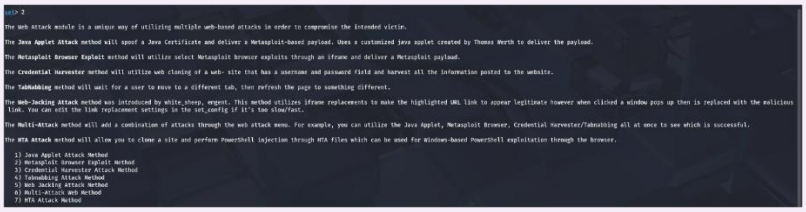


Fig 4.2 — Website Attack Vectors sub-menu listing all available web-based attack methods

SET describes the Credential Harvester method: it clones a site with a username/password form and captures all data submitted. The attacker's IP is used as the POST-back address.

Step 21: Select option 3 (Credential Harvester Attack Method) from Website Attack Vectors.

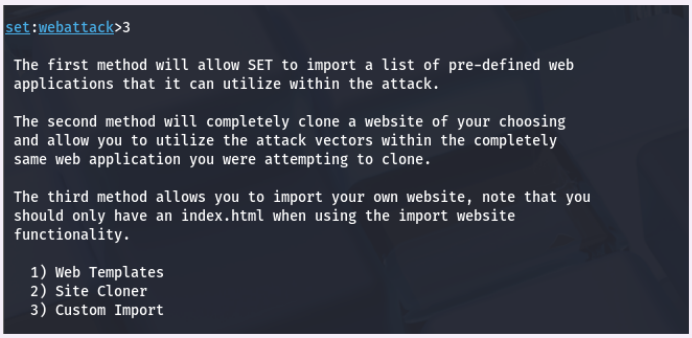


Fig 4.3 — Credential Harvester method description and template/clone/import options

4.2 Template Method — Google Login Clone

Select option 1 (Web Templates). Enter the attacker's IP address for the POST-back listener. Then select template 2 (Google) to serve a pre-built Google login page clone hosted on the attacker's machine.

Step 22: Enter the attacker IP and select Web Templates (option 1), then choose Google (option 2).



Fig 4.4 — Attacker IP entry and Google template selection for the credential harvester

The cloned Google login page is now served at the attacker's IP address. Any victim who navigates to this URL sees a pixel-perfect replica of the real Google sign-in page.

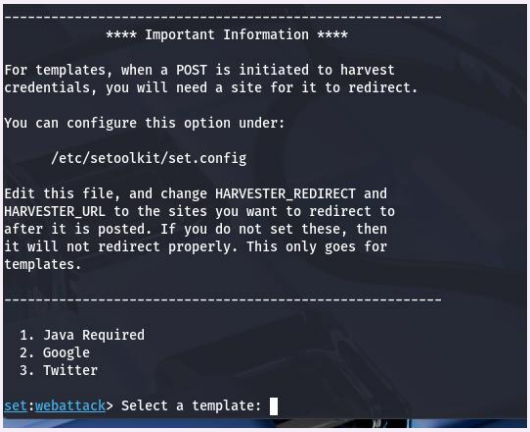


Fig 4.5 — Cloned Google login page served at attacker IP (browser view)

4.3 Credentials Captured

When a victim enters their email and password and clicks Sign In, SET intercepts the POST request. The terminal displays all submitted parameters, with the username and password fields highlighted in red, confirming successful capture.

Step 23: Enter test credentials on the cloned page to simulate victim behavior.

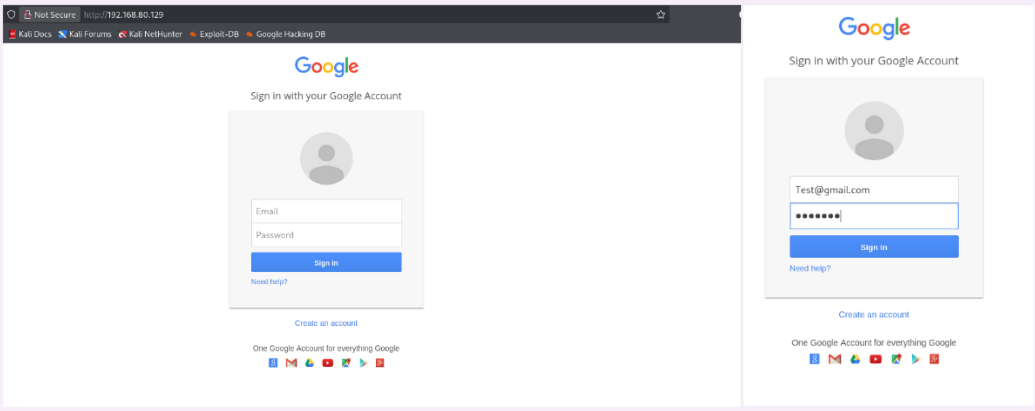


Fig 4.6 — Test credentials entered on the cloned Google login page

Step 24: Observe SET terminal — captured fields (POSSIBLE USERNAME / POSSIBLE PASSWORD) appear in red.



Fig 4.7 — SET terminal output: captured username and password fields displayed

Note: POSSIBLE USERNAME FIELD FOUND and POSSIBLE PASSWORD FIELD FOUND are printed in the terminal, confirming successful credential capture in cleartext. Hit CTRL+C in the terminal to stop the harvester and generate a final capture report.

5. Site Cloner — Directing Victims via Gmail Link Spoofing

A more targeted delivery method involves cloning a website with SET's Site Cloner, then crafting a Gmail message where the displayed anchor text shows a legitimate URL while the actual href points to the attacker's cloned page. This exploits user trust in recognizable domain names displayed in email clients.

5.1 Cloning the Target Website

From Website Attack Vectors, select option 2 (Site Cloner). Enter the attacker's IP and the URL to clone. SET downloads and mirrors the full page on its local HTTP server.

Step 25: Return to Website Attack Vectors and select option 3 (Credential Harvester) > option 2 (Site Cloner).

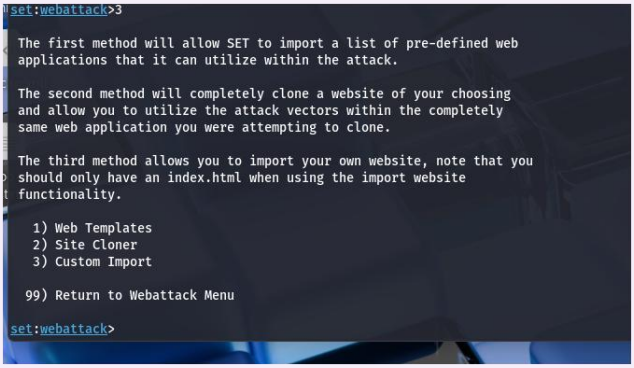


Fig 5.1 — SET Website Attack Vectors: entering IP and URL to clone (http://google.com/login)

SET confirms the cloning is in progress. The cloned page is then served locally and verified in the browser.

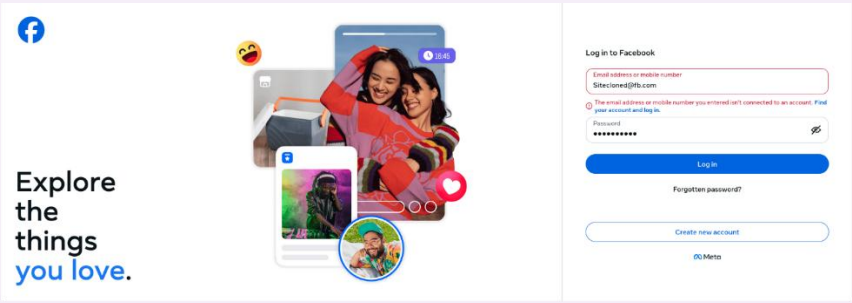


Fig 5.2 — Browser: cloned Facebook login page loaded from the attacker's local server

5.2 Crafting the Deceptive Gmail Link

In Gmail Compose, the visible anchor text is set to a legitimate URL (https://google.com) while the actual hyperlink destination is configured to point to the attacker's IP hosting the cloned page. The victim sees a trusted link but lands on the fake site when they click.

Step 26: Open Gmail and click Compose to start a new message.

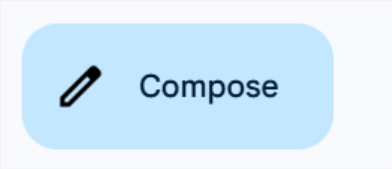


Fig 5.3 — Gmail: Compose button to start a new message

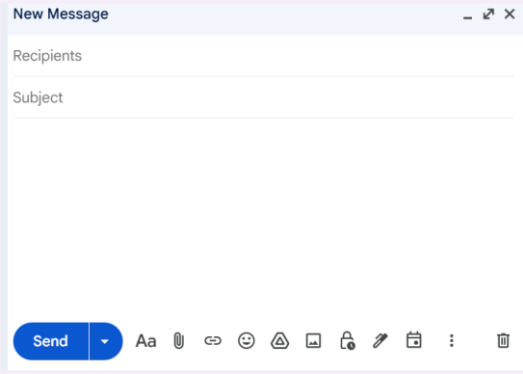


Fig 5.4 — Gmail: New Message compose window open and ready

Step 27: Add the target email address and type the message body text.

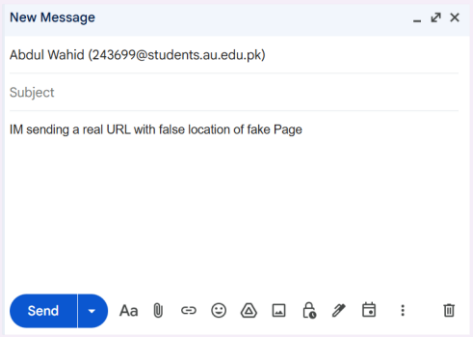


Fig 5.5 — Gmail compose: recipient added (243699@students.au.edu.pk) and body typed

Step 28: Click the link icon. Set display text to the real URL; set the actual link to the attacker's IP.

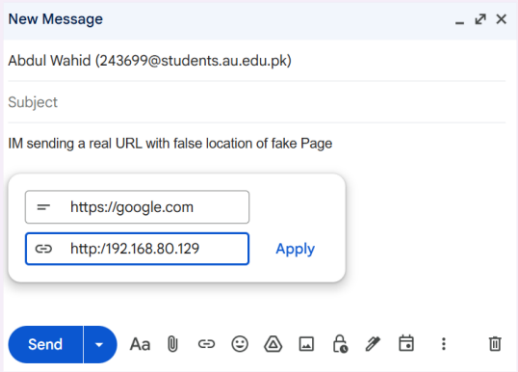


Fig 5.6 — Gmail link dialog: display text = https://google.com | actual link = http://192.168.80.129

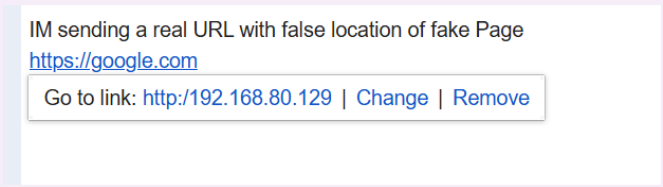


Fig 5.7 — Gmail compose: link inserted, tooltip shows the real (fake) destination on hover

5.3 Victim Redirected to Cloned Page

When the victim clicks the link in the email, they are taken directly to the attacker's cloned login page. The browser address bar reveals the attacker's IP, but the page content visually mirrors the real site. Any credentials submitted are captured by SET's listener.

Step 29: Click the link to simulate victim behavior — confirm redirection to the cloned page.

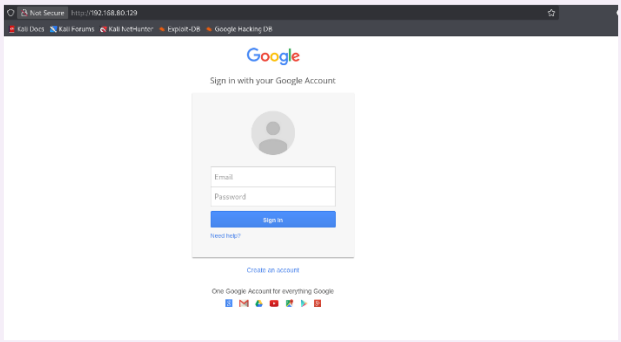
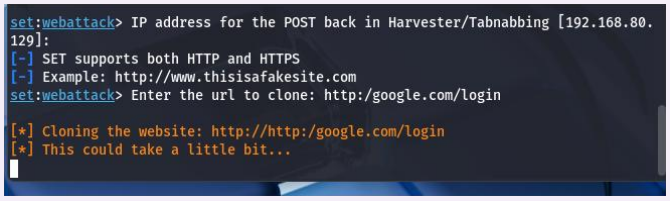


Fig 5.8 — Browser: victim redirected to the cloned Google login page at attacker's IP



Monitoring

6. Findings Summary

Attack Module	Status	Notes
Mass Mailer — Payload Generation	✓ Success	payload.exe generated; Metasploit listener launched successfully.
Netcat Listener	✓ Success	nc -lvnp 4444 confirmed listening on all interfaces.
Mass Mailer — Link Shortening	✓ Success	Bitly shortened URL created and confirmed.
Mass Mailer — Email Delivery	⚠ Auth Error	Gmail SMTP password error — resolvable via App Password with 2FA.
Credential Harvester — Google	✓ Success	Credentials captured in cleartext (email + password).
Site Cloner — Facebook	✓ Success	Cloned page served and confirmed visually identical.
Email Link Spoofing (Gmail)	✓ Success	Victim redirected to cloned page via href manipulation.

7. Conclusion

This lab successfully demonstrated the core capabilities of SET for simulating real-world social engineering attacks. The Mass Mailer module provides an efficient framework for phishing campaigns, while the Credential Harvester and Site Cloner modules illustrate how convincingly legitimate websites can be replicated to steal user credentials. The only partial failure was the Gmail SMTP authentication error in the Mass Mailer delivery step — a configuration issue, not a SET limitation.

> **Important:** All activities documented in this report were performed exclusively in a closed, authorized lab environment. No real users or systems were targeted without consent.